

Подтверждение личности с нулевым разглашением информации

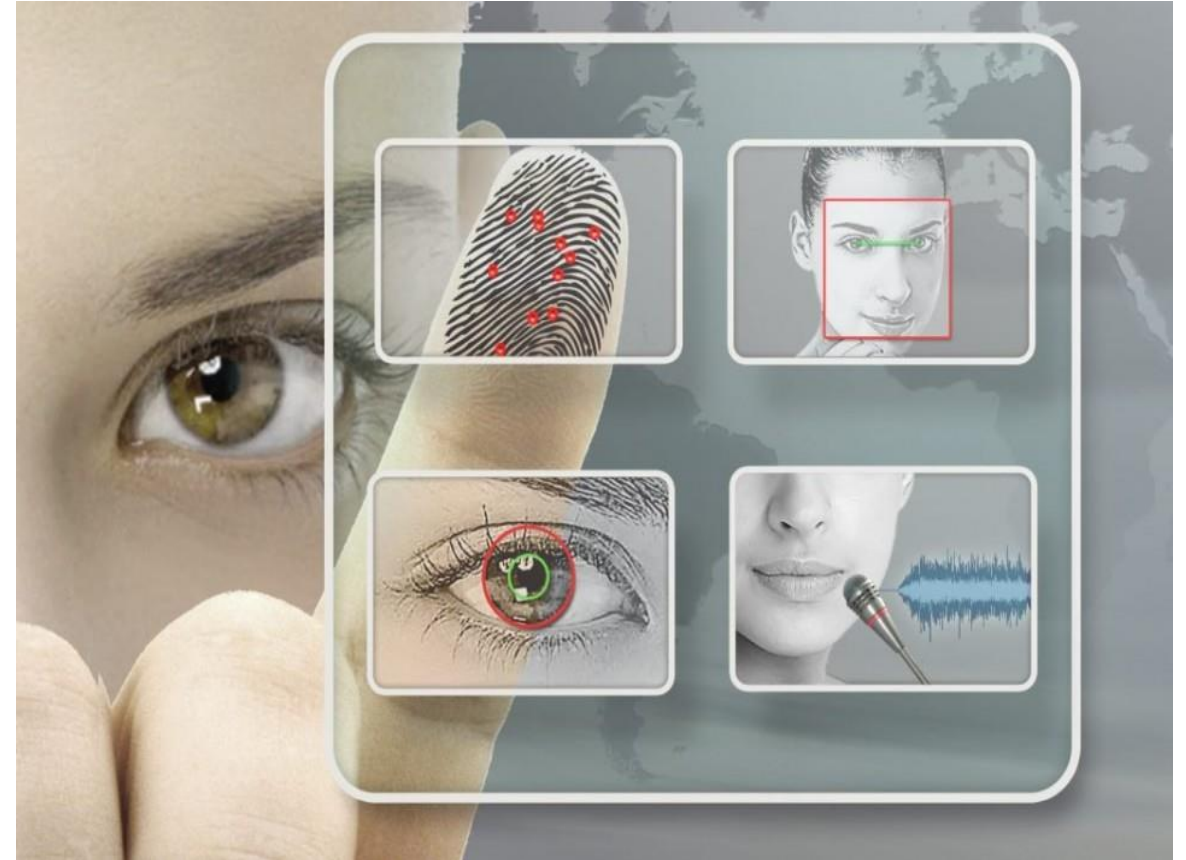
- Сервер или контроллер домена должен допустить (или не допустить) пользователя к информации, хранящейся в сети.
- При этом пользователь не хочет, чтобы злоумышленник, прослушивающий канал передачи данных, или сам сервер узнали его пароль.



Рассмотрим протокол «доказательства с нулевым знанием» для идентификации личности **без использования различных физических устройств и данных (символов), таких как:**

- паспорт,
- различные снимки человека
(сетчатки глаза, пальцев рук,
лица и т. д.),

а принципиально другим образом.



Многораундовые протоколы с нулевым разглашением включают многократное повторение трех типовых шагов

- 1) Доказывающий генерирует разовый случайный секретный ключ, вычисляет по нему разовый открытый ключ (фиксатор) **x**, который передается проверяющему.
- 2) Проверяющий генерирует нулевой (**e = 0**) или единичный (**e = 1**) запрос с вероятностью $\frac{1}{2}$ и отправляет бит запроса **e** доказывающему.
- 3) Доказывающий вычисляет ответ **y** и отправляет найденный **y** проверяющему.

После каждого такого трехшагового раунда проверяющий подставляет полученный им ответ в некоторое проверочное соотношение.

Если это соотношение выполняется, то проверяющий считает, что **текущий ответ правильный**.

Протокол Фиата-Шамира

Использование доказательств с нулевым разглашением в качестве доказательства идентичности было впервые предложено **Амосом Фиатом** и **Ади Шамиром**.



Амос Фиат



Ади Шамир

Протокол Фиата-Шамира

Пусть **A** знает некоторый секретный (закрытый) ключ **s**. Он используется для определения идентичности: закрытый ключ у **A** является так называемым «показателем идентичности».

Необходимо доказать знание этого закрытого ключа некоторой стороне **B** без разглашения какой-либо секретной информации.

A (Alice) — доказывающий

B (Bob) — проверяющий

Описание протокола Фиата-Шамира

Предварительные действия

Доверенный центр **T** выбирает и публикует модуль (открытый параметр N):

$$N = pq,$$

где p, q — большие простые числа (они держатся в секрете).

Далее **A** выбирает число s , взаимно простое с N , где $s \in [1, N - 1]$.

Затем вычисляется $v = s^2 \bmod N$, v регистрируется **T** в качестве открытого ключа **A**.

Стойкость протокола основывается на сложности извлечения квадратного корня по модулю достаточно большого составного числа N , факторизация которого неизвестна.

Основные действия (этапы каждого раунда):

Следующие действия последовательно и независимо выполняются **t** раз.

A доказывает **B** знание **s** в течение **t** раундов (аккредитаций).

B считает знание доказанным, если все **t** раундов прошли успешно.

1. **A** выбирает случайное **r**, такое, что $r \in [1, N - 1]$ и отправляет $x = r^2 \bmod N$ стороне **B** (доказательство).

2. **B** случайно выбирает бит **e** (**e** = 0 или **e** = 1) и отправляет его **A** (вызов).

3. **A** вычисляет $y = rs^e \bmod N$ и отправляет его обратно к **B**.

Если **e** = 0, то $y = r$, иначе (при **e** = 1) $y = rs \bmod N$.

4. Если **y** = 0, то **B** отвергает доказательство (т.е. **A** не удалось доказать знание **s**). Иначе сторона **B** проверяет, действительно ли $y^2 = xv^e \bmod N$ и если это так, то происходит переход к следующему раунду протокола.

Выбор **e** из множества $\{0, 1\}$ предполагает, что если сторона **A** действительно знает секрет, то она всегда сможет правильно ответить, вне зависимости от выбранного **e**.

Допустим, что **A** хочет обмануть **B**. В этом случае **A** может отреагировать только на конкретное значение **e**.

Например, если **A** предполагает, что получит **e = 0**, то ей можно действовать строго по инструкции (по протоколу).

Если же **A** предполагает, что получит **e = 1**, то ей необходимо действовать НЕ по протоколу.

Если **A** предполагает, что получит $e = 0$, то ей можно действовать строго по инструкции (по протоколу).

1. **A** выбирает случайное r , такое, что $r \in [1, N - 1]$ и отправляет $x = r^2 \bmod N$ стороне **B**.

2. **B** случайно выбирает бит e ($e = 0$ или $e = 1$) и отправляет его **A**.

3. **A** вычисляет $y = rs^e \bmod N$ и отправляет его обратно к **B**. Если на шаге 2 **B** выбрал $e = 0$, то $y = r$.

Тогда на шаге 4 проверка **будет пройдена успешно**.

4. Так как $y \neq 0$, то сторона **B** проверяет, действительно ли $y^2 = xv^e \bmod N$:

$$xv^e = xv^0 = x = r^2 = y^2 \pmod{N}$$

Если **A** предполагает, что получит $e = 0$, то ей можно действовать строго по инструкции (по протоколу). Однако если на шаге 2 **B** выбрал $e = 1$, то проверка **не будет пройдена**.

1. **A** выбирает случайное r , такое, что $r \in [1, N - 1]$ и отправляет $x = r^2 \bmod N$ стороне **B**.

2. **B** случайно выбирает бит e ($e = 0$ или $e = 1$) и отправляет его **A**.

3. **A** вычисляет $y = rs^e \bmod N$ и отправляет его обратно к **B**. Если на шаге 2 **B** выбрал $e = 1$, то $y = rs^1 \bmod N = rs \bmod N$. Не зная секретного s , сторона **A** не сможет правильно вычислить y .

4. Тогда на шаге 4 проверка **не будет пройдена** (сторона **B** проверяет, действительно ли $y^2 = xv^e \bmod N$).

Если **A** предполагает, что получит $e = 1$, то она действует НЕ по протоколу.

1. **A** выбирает случайное $r \in [1, N-1]$ и отправляет $x = \frac{r^2}{v} \bmod N$ на сторону **B**
(вместо $x = r^2 \bmod N$).

2. **B** случайно выбирает бит e ($e = 0$ или $e = 1$) и отправляет его **A**.

3. **A** направляет на сторону **B** $y = r$. Если на шаге 2 **B** выбрал $e = 1$, то на шаге 4 проверка **будет пройдена успешно**.

4. Если на шаге 2 **B** выбрал $e = 1$, то он проверяет, действительно ли $y^2 = xv^e \bmod N$, т.е. $y^2 = xv \bmod N$:

$$xv = \left(\frac{r^2}{v}\right)v = r^2 = y^2 \pmod{N}.$$

Если **A** предполагает, что получит $e = 1$, то она действует НЕ по протоколу.

Однако если на шаге 2 **B** выбрал $e = 0$, то проверка **не будет пройдена**.

1. **A** выбирает случайное $r \in [1, N-1]$ и отправляет $x = \frac{r^2}{v} \bmod N$ на сторону **B**
(вместо $x = r^2 \bmod N$).

2. **B** случайно выбирает бит e ($e = 0$ или $e = 1$) и отправляет его **A**.

3. **A** направляет на сторону **B** $y = r$. Если на шаге 2 **B** выбрал $e = 0$, то на шаге 4 проверка **не будет пройдена**.

4. Если на шаге 2 **B** выбрал $e = 0$, то он проверяет, действительно ли $y^2 = xv^0 \bmod N$, т.е. $y^2 = x \bmod N$:

$$x = \frac{r^2}{v} \neq y^2 \pmod{N}.$$

Проблема заключается в том, что **A** изначально не знает, какое **e** она получит и поэтому не может со 100 % вероятностью выслать на сторону **B** нужный для обмана **x** (**x** = **r**² при **e** = 0 и **x** = **r**²/**v** при **e** = 1).

В случае, если **A** заранее не знает значение **e**, которое она получит от **B**, то не сможет правильно ответить, т.к. не знает **s**, а извлечь квадратный корень из **v** по модулю **N** достаточно сложно.

Поэтому вероятность обмана в одном раунде составляет **50 %**. Вероятность жульничества в **t** раундах равна $(\frac{1}{2})^t = \frac{1}{2^t}$.

Чтобы вероятность обмана после **t** раундов была близка к нулю, **t** выбирают достаточно большим (**t** = 20 ,..., 40). Таким образом, **B** удостоверяется в знании **A** тогда и только тогда, когда все **t** раундов прошли успешно.

Пример.

- Пусть доверенный центр выбрал простые $p=683$ и $q=811$, тогда $n=683*811=553913$.
A выбирает $s=43215$.

Откуда $v = 43215^2 \pmod{553913} = 1867536225 \pmod{553913} = 295502$

- **A** выбирает $r=38177$ и считает

$$x = 38177^2 \pmod{553913} = 1457483329 \pmod{553913} = 138226$$

- Если **B** отправил $e=0$, то **A** возвращает $y=38177$. Иначе, **A** возвращает
 $y = 38177 * 43215 \pmod{553913} = 1649819055 \pmod{553913} = 266141$

- Проверка **B**: $y^2 \equiv x * v^e \pmod{n}$

Если **e** было равно 0, то $y^2 = 38177^2 \pmod{553913} = 1457483329 = 138266$

Подтверждено.

Иначе, $y^2 = 266141^2 \pmod{553913} = 70831031881 \pmod{553913} = 514832$

и $x * v = 138226 * 295502 \pmod{553913} = 40846059452 \pmod{553913} = 514832$

Подтверждено.

Для того, чтобы этот протокол корректно выполнялся, сторона **A** никогда не должна повторно использовать значение **x**.

Если бы **A** поступила таким образом, а **B** во время другого цикла отправил бы **A** на шаге 2 другой случайный бит **e**, то **B** бы имел оба ответа **A**:

$$1. \mathbf{y = rs^0 \text{ mod } N = r \text{ mod } N}$$

$$2. \mathbf{y = rs^1 \text{ mod } N = rs \text{ mod } N}$$

После этого **B** сможет вычислить значение **s**, и ему будет известен секретный ключ **A**.

Протокол Фейге – Фиата – Шамира

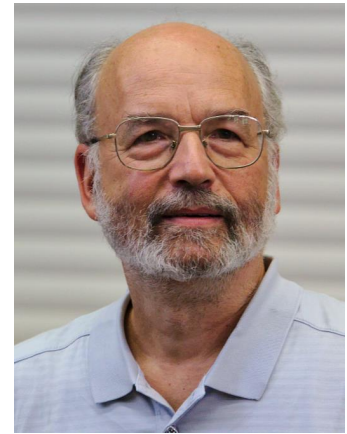
Протокол идентификации с нулевым разглашением, обобщение более раннего протокола **Фиата — Шамира**, разработанный **Уриэлем Фейге** (Uriel Feige), **Амосом Фиатом** (Amos Fiat) и **Ади Шамиром** (Adi Shamir) в 1986 году.



Уриэль Фейге



Амос Фиат



Ади Шамир

Протокол позволяет одному участнику (доказывающему **А**) доказать другому участнику (проверяющему **В**), что он обладает секретной информацией, не раскрывая ни единого бита этой информации.

Описание протокола Фейге – Фиата – Шамира

Выбор параметров системы

Доверенный центр **T** публикует большое число $n = pq$, где p и q — простые числа, которые держатся в секрете. Также выбираются целые числа k и t - параметры безопасности.

Генерация секретов для участников

Каждый участник выбирает k случайных целых чисел $s_1, s_2, \dots, s_k, 1 \leq s_i \leq n - 1$ и k случайных бит $b_1, b_2, \dots, b_k$.

Затем вычисляет $v_i = (-1)^{b_i} \cdot (s_i^2)^{-1} \mod n, 1 \leq i \leq k$.

Участник идентифицирует себя окружающим с помощью значений $(v_1, v_2, \dots, v_k; n)$, которые выступают в качестве его открытого ключа, в то время как секретный ключ $s = (s_1, s_2, \dots, s_k)$ известен только самому участнику.

Действия протокола в рамках одного раунда

1. **A** выбирает случайное целое число r , $1 \leq r \leq n - 1$

вычисляет: $x = r^2 \mod n$ и отправляет x стороне **B**.

2. **B** отправляет **A** случайный k -битный вектор $(e_1, e_2, \dots, e_k)$, где $e_i = 0$ или $e_i = 1$.

3. **A** вычисляет и отправляет **B**: $y = r \cdot \prod_{i=1}^k s_i^{e_i} \mod n$.

4. **B** вычисляет: $z = y^2 \cdot \prod_{i=1}^k v_i^{e_i} \mod n$ и проверяет, что $z = \pm x \mod n$
и $z \neq 0$.

Лемма 1: Если **A** и **B** следуют протоколу, то **B** всегда принимает доказательства **A**: **Доказательство:** по определению

$$z = y^2 \cdot \prod_{i=1}^k v_i^{e_i} = r^2 \cdot \prod_{i=1}^k (s_i^{2e_i} v_i^{e_i}) = \pm r^2 = \pm x \mod n$$

В предположении, что разложение n на множители - вычислительно невозможная задача, вероятность успешной атаки на протокол составляет 2^{-kt} .

Злоумышленник может попытаться выдать себя за честного пользователя путём угадывания

правильных значений e_i , приготовления $x = \pm r^2 \cdot \prod_{i=1}^k v_i^{e_i} \mod n$ для первого шага и

предоставления $y = r$ на третьем шаге.

Тогда **B** убедится, что $z = y^2 \cdot \prod_{i=1} v_i^{e_i} = r^2 \cdot \prod_{i=1} v_i^{e_i} = \pm x$. Но вероятность правильно выбрать k значений $(e_1, e_2, \dots, e_k)$ составляет 2^{-k} в одном раунде и, следовательно, 2^{-kt} во всем протоколе.

Таким образом, для достижения уровня безопасности, например, 2^{-20} достаточно выбрать $k = 5$ и $t = 4$. Это означает, что только одна из миллиона попыток нечестного пользователя обмануть проверяющего может увенчаться успехом.

Протокол доказывает, что **A** обладает своим секретным ключом, не раскрывая никакого знания о нём, когда $k = O(\log \log n)$ и $t = O(\log n)$.

Пример.

1. Пусть доверенный центр **T** выбрал простые числа $p = 683$ и $q = 811$ и опубликовал $n = pq = 553913$. Параметры безопасности системы: $k = 3, t = 1$.
2. Для участника **A** выбираются случайные числа: $s_1 = 187, s_2 = 37411, s_3 = 5204$ и 3 бита: $b_1 = 1, b_2 = 1, b_3 = 0$.
вычисляются значения: $v_1 = 307124, v_2 = 115268, v_3 = 403211$.
Публичный ключ **A**: $(307124, 115268, 403211; 553913)$, секретный ключ: $(187, 37411, 5204)$.
3. (a) **A** выбирает случайное число $r = 1337$, случайный бит $b = 1$, вычисляет: $x = 428083$ и пересылает его **B**.
(b) **B** посылает **A** 3-битный вектор: $(0, 1, 0)$.
(c) **A** вычисляет и отправляет **B**: $y = r \cdot s_2 \mod n = 166337$.
(d) **B** вычисляет: $z = y^2 \cdot v_2 \mod n = 428083$ и принимает доказательство **A**, так как $z = \pm x \mod n$ и $z \neq 0$.

Улучшения и модификации схемы идентификации

1. Можно отказаться от выбора общего для всех участников числа n и позволить каждому из них выбирать своё собственное. Однако существование доверенного центра **T** по-прежнему будет необходимо для того, чтобы ассоциировать каждого участника с его модулем.
2. Для того чтобы снизить сложность взаимодействия между **A** и **B**, можно заменить первое посылаемое от **A** к **B** сообщение x на значение хеш-функции $h(x)$. Соответственно, на последней итерации протокола **B** должен будет оперировать $h(z)$ вместо самого z .

3. Схему можно изменить так, чтобы она основывалась на идентичности каждого участника.

Для этого каждому пользователю **A** доверенный центр **T** назначает уникальную идентифицирующую строку I_A с информацией об участнике (например, имя, адрес, номер паспорта и т. д.). Затем центр вычисляет значения $v_i = f(I_A, i)$, $1 \leq i \leq k$, где f должна быть неотличима от случайной функции за полиномиальное время. Потом, зная факторизацию n , доверенный центр вычисляет $s_i = \sqrt{v_i^{-1}} \pmod n$ и выдает их значения **A**. Значения v_i и s_i становятся, соответственно, открытым и секретным ключами участника **A**, и дальнейшие действия выполняются по схеме, описанной выше.

4. Описанный протокол можно выполнять параллельно. В таком случае сообщения, передаваемые от **A** к **B** и обратно, должны содержать данные для всех t раундов одновременно. Плюс данного подхода в том, что он позволяет снизить сложность выполнения за счёт уменьшения количества производимых итераций. Такая схема является безопасной, но в силу технических причин теряет своё свойство нулевого разглашения.

Дело в том, что параллельное выполнение может позволить нечестному проверяющему **B** определять e_{it} не случайным образом, а как функции от всего набора x_t , присылаемого ему от **A** на первом шаге. Если **B** будет делать это, используя одностороннюю хеш-функцию, то он сможет получить информацию, которую иначе мог бы вычислить только при условии знания секрета **A**. Однако считается, что эта информация не является «полезной» (зная её, **B** не сможет выдать себя за **A** какому-то другому участнику), что позволяет считать схему по-прежнему надёжной.

Злоупотребления доказательством с нулевым разглашением

Предложено несколько способов злоупотребления доказательством с нулевым разглашением, которые используют те или иные слабые стороны протокола.

- **Проблема гроссмейстера**
- **Обман, выполненный мафией**
- **Террористическое мошенничество**
- **Обман с несколькими личностями**
- **Аренда паспортов**

Проблема гроссмейстера

- Алиса играет против двух гроссмейстеров, которые находятся в разных комнатах и не знают о присутствии друг друга.
- Алиса записывает ходы одного гроссмейстера и дублирует их в игре с другим, затем записывает ходы второго и повторяет с первым, и так далее.
- Таким образом это продолжается до того момента, пока она не проиграет одну партию, выигрывая вторую, или пока обе партии не закончатся вничью.
- Использование этого обмана позволяет обмануть любого шахматиста и выиграть благодаря не своим знаниям.

Данная методика обмана может использоваться против доказательства личности с нулевым разглашением.

Обман, выполненный мафией

- Пусть имеется 4 участника: А, В, С, D. Причём В и С сотрудничают между собой («принадлежат одной мафии»). А доказывает свою личность В, а С хочет выдать себя за А перед D.
- В владеет рестораном, принадлежащим мафии, С — также представитель мафии, D — хозяин ювелирной лавки. А и D не знают о предстоящем мошенничестве.
- В момент, когда А готов заплатить за обед и идентифицировать себя перед В, В извещает С о начале мошенничества. Это возможно благодаря наличию радиоканала между ними. В это время С выбирает бриллиант, который хочет купить, и D начинает идентифицировать личность С, который выдает себя за А.

- С передаёт протокольный вопрос к В, а тот в свою очередь, задаёт его А.
- Ответ передаётся в обратном порядке. Таким образом А заплатит не только за обед, но и за дорогой бриллиант.

Как видно из вышеописанного, существуют определённые требования для подобного мошенничества.

Когда А начинает доказывать свою личность перед В, а С — перед D, действия В и С должны быть синхронизированы. Данное злоупотребление тоже разрешимо. Например, если в магазине ювелира будет клетка Фарадея, то «мафиози» не смогут обмениваться сообщениями.

Террористическое мошенничество

- Если Алиса захочет сотрудничать с Кэрол, они также смогут обмануть Дэйва. В этом протоколе Кэрол — известная террористка. Алиса помогает ей въехать в страну. Дэйв — сотрудник иммиграционной службы. Алиса и Кэрол связаны секретной радиосвязью.
- Когда Дэйв задает Кэрол вопросы в рамках протокола с нулевым разглашением, Кэрол передает их по радио Алисе, которая сама на них отвечает. Кэрол пересказывает эти ответы Дэйву. На самом деле Алиса доказывает свою личность Дэйву, а Кэрол выступает в качестве канала связи.
- Когда протокол заканчивается, Дэйв думает, что Кэрол — это Алиса, и пропускает ее в страну. Три дня спустя Кэрол появляется в каком-то правительственном здании с минивэном, набитым взрывчаткой.

Предлагаемые решения вышеуказанных мошенничеств

- Возможны как мафиозные, так и террористические мошенничества, поскольку **заговорщики могут общаться через секретное радио**. Один из способов предотвратить это — проводить все идентификации внутри клеток Фарадея, которые блокируют все электромагнитное излучение.
- В примере с террористом это дает сотруднику иммиграционной службы Дейву уверенность в том, что Кэрол не получала ответов от Алисы. В примере с мафией Боб мог бы просто построить неисправную клетку Фарадея в своем ресторане, но у ювелира Дэйва была бы работающая клетка; Боб и Кэрол не смогут общаться. Чтобы решить задачу гроссмейстера по шахматам, Алису нужно заставить сидеть на своем месте до конца игры.

- Томас Бет и Иво Десмедт предложили другое решение, использующее точные часы. Если каждый шаг протокола должен происходить в определенное время, у заговорщиков не будет времени для общения.
- В задаче о гроссмейстере по шахматам, если каждый ход в каждой игре должен быть сделан до того, как часы пробьют одну минуту, то у Алисы не будет времени бегать из комнаты в комнату.
- В истории «Мафии» у Боба и Кэрол не будет времени обмениваться вопросами и ответами.

Обман с несколькими личностями

- В доказательствах с нулевым разглашением предполагается, что доказывающая сторона владеет некоторым секретом, который идентифицирует её личность. Секрет доказывающая сторона получает от доверенного центра.
- Допустим, что при выдаче секрета внешность индивидуума не проверяется, или она не уникальна, или не может быть проверена надлежащим образом. Тогда эта сторона может сгенерировать несколько секретов, записать их в открытый файл доверенного центра, и следовательно у неё будет «несколько личностей». Такая возможность позволяет, например, совершить преступление и безнаказанно скрыться.

- Пусть сторона создает несколько личностей, одну из которых никогда не использует. Затем, во время совершения преступления сторона идентифицирует себя этой, никогда не используемой личностью.
- После преступления личность никогда больше не используется. Таким образом, выследить преступника практически невозможно.
- **Простейший способ предотвращения обмана с несколькими личностями предполагает**, что доказывающая сторона не может иметь более одной личности.

Аренда паспортов

- Алиса хочет поехать в Заир, но правительство не дает ей визу. Кэрол предлагает передать свою личность Алисе. Кэрол продает Алисе свой закрытый ключ, и Алиса уезжает в Заир, притворяясь Кэрол.
- Кэрол не только заплатили за ее личность, но теперь у нее есть идеальное алиби. Она совершает преступление, пока Алиса находится в Заире. «Кэрол» подтвердила свою личность в Заире; как она могла совершить преступление дома?
- Конечно, Алиса тоже может совершать преступления. Она делает это либо перед отъездом, либо после возвращения, возле дома Кэрол. Сначала она называет себя Кэрол (у нее есть закрытый ключ Кэрол, поэтому она легко может это сделать), затем совершает преступление и убегает. Полиция придет искать Кэрол. Кэрол будет утверждать, что сдала свою личность Алисе, но кто ей поверит?

- Проблема в том, что Алиса на самом деле не подтверждает свою личность; она доказывает, что знает часть секретной информации. Это связь между этой информацией и человеком, которому она принадлежит, которой злоупотребляют.
- От такого рода мошенничества может уберечь полицейское государство, где всем гражданам придется очень часто подтверждать свою личность (в конце каждого дня, на каждом углу улицы и т. д.). Биометрические методы — отпечатки пальцев, сканирование сетчатки, голосовые отпечатки и т. д. — могут помочь решить эту проблему.